

DDTA research work plan after documentation-layer closure

WORK PLAN - REVISION 1

Baseline: 9a04bc5b98b7f4a2b8400f2b210e7cea6b04d1a9

This plan **supersedes earlier sequencing notes** that placed formal Base Analysis before SecurityRequirement design. It changes the research sequence, not the closed MR/Decision/FR semantic rules. SecurityRequirement semantics will be defined method-neutrally before Base Analysis/overlay construction; analytical provenance from Finding to SEC will be integrated later.

1. Current checkpoint

The documentation-authoring metamodel is frozen for the current thesis scope through:

Project problem framing [method precondition]

- > MacroRequirement
- > Decision
- > FunctionalRequirement
- > SpecializedRequirement

Closed working rules include:

- regular MR -> Decision -> FR hierarchy;
- exactly one MR parent per Decision;
- exactly one Decision parent per FR;
- controlled necessity/default Decision for rare singleton-solution cases;
- no Decision below FR;
- normative FR prose is primary and is supported by governed SPO references;
- cross-MR capability consumption does not transfer ownership;
- exact analytical representation of referenced subjects/services remains deferred.

The documentation baseline is reopenable only for a concrete counterexample from the next phases.

2. Immediate thesis-writing checkpoint

W0 - Chapter 4 candidate

Produce and review a standalone thesis Chapter 4 covering only:

- problem framing;
- MR metamodel and authoring rules;
- Decision metamodel, responsibility boundary and necessity/default rule;
- FR operational semantics, normative prose + SPO, FunctionalPredicate and parameter classification;
- cross-MR service consumption and tool-authority boundary;
- validation history and explicit reopen conditions.

Do not integrate the chapter into the master thesis file until human review is complete.

Exit gate: chapter accepted as an accurate description of the current documentation baseline.

3. Specialized Requirement and Security Requirement before threat methods

S1 - Minimal SpecializedRequirement semantics

Define the smallest method-independent meaning shared by specialized requirements.

Questions:

1. What does specialization add to an FR: constraint, additional obligation, applicability condition, or a combination?
2. Is the relation conceptually **specializes**, **constrains**, **appliesTo**, or something smaller/more neutral?
3. Can one FR have multiple independent specialized requirements?
4. How is effective obligation constructed without copying specialized text into the FR?
5. Which common identity/lifecycle/provenance concepts are inherited from GovernedDocument rather than redefined?

Exit gate: a minimal common contract that does not assume Security, Governance, Privacy or Performance-specific semantics.

S2 - SecurityRequirement semantic model

Define **SecurityRequirement** before STRIDE, STRIDE-AI or another threat method is used as construction evidence.

Fundamental research question candidate:

Which additional security obligation must the governed functional capability satisfy so that a required security property is preserved under the relevant conditions, independently from the method that discovered or motivated the obligation?

Required tests:

- meaningful with all STRIDE category names removed;
- meaningful if a different security method, expert review, incident, penetration test or regulatory assessment motivates it;
- clearly distinguishable from FR, Decision, control/implementation mechanism and verification evidence;
- does not embed threat-method payload in the SEC semantic core;
- supports later analytical provenance without requiring that provenance to define what the SEC means.

S3 - Independent SecurityRequirement authoring corpus

Author **SecurityRequirement** examples without running STRIDE.

Use at least two domains already understood by the study, but do not derive the corpus from threat-category enumeration. Include positive and negative classification examples:

- valid SEC;
- statement that is still an FR;
- statement that is a Decision;
- implementation/control mechanism;
- verification/evidence statement.

Exit gate: SEC semantics survive independent review and regression without methodology vocabulary.

4. Formal Base Analysis phase

BA1 - Base Analysis responsibility and boundary

Freeze what Base Analysis must provide and must not provide.

Candidate direction to test:

a governed, method-neutral graph of stable analysis-relevant system/project subjects and relations, integrated from explicit governed documentation and reviewed analytical additions.

Do not use STRIDE categories to define the common graph.

BA2 - BAE ontology

Test and close the smallest generic subject vocabulary needed by real project descriptions. Candidate pressure points include:

- Actor;
- Component / Service capability;
- DataResource;
- DataStore;
- DataFlow / Interaction;
- CommunicationChannel;
- InterfaceContract;
- Boundary.

Open distinctions must be tested rather than copied from ThreatForge.

BA3 - Base Analysis relations, provenance and authority

Formalize:

- stable identity;
- source/target/carries and other generic relations;
- origin: governed document vs reviewed analytical addition;
- authoritative source vs supporting sources;
- lifecycle/staleness hooks;
- document/SPO reference -> BAE resolution;
- cross-MR service/capability consumption target.

BA4 - Authoring-to-Base-Analysis integration

Define how MR/Decision/FR authoring creates or references analysis-relevant system facts without automatic noun-to-BAE canonization.

Exit gate: a method-neutral Base Analysis graph can be built from governed documentation plus explicit reviewed additions without changing the documentation hierarchy.

5. Generic analysis envelope before concrete overlay

A1 - AnalysisRecord common contract

Reconfirm method-independent fields for an analysis execution/interpretation while keeping method-specific payload opaque and plugin-owned.

A2 - Common Finding contract

Reconfirm a reviewed common downstream finding envelope that can identify affected governed subjects and preserve evidence/rationale without copying method-specific taxonomies to the top level.

A3 - Finding -> SecurityRequirement integration

Only after S2/S3 and A1/A2 are stable, define analytical provenance:

AnalysisRecord -> Finding -> accepted/reviewed -> SecurityRequirement

The test is whether a Finding can propose/justify an SEC that conforms to the **already defined** SEC semantics. If the SEC model must be changed merely to fit a method payload, treat that as methodology contamination unless a method-independent counterexample justifies the change.

6. Method-neutral overlay/plugin contract

O1 - Generic overlay contract

Define what every analysis method/plugin may receive and return without prescribing a specific taxonomy:

- compatibility/version contract;
- scope selection over Base Analysis subjects/relations/FRs;
- method-owned payload schema;
- diagnostics for missing/inadequate analysis context;
- deterministic/common Finding derivation boundary;
- failure/incompatibility behavior;
- preservation of common records even if a plugin is unavailable.

Exit gate: a hypothetical non-STRIDE security method can implement the contract without changing the common core.

7. Concrete methodology tests

O2 - STRIDE overlay

Implement/use STRIDE as the first concrete overlay only after S1-S3, BA1-BA4 and O1 are frozen enough for falsification.

Evaluation questions:

- Does STRIDE consume Base Analysis without method-specific changes to BAE?
- Can all STRIDE-specific semantics remain in the plugin payload/logic?
- Can findings be expressed in the common Finding envelope?
- Can accepted findings produce SEC instances without changing the SEC semantic core?

O3 - Closed-loop design improvement

Exercise the complete DDTA loop:

governed documentation

- > Base Analysis
- > STRIDE overlay
- > AnalysisRecord
- > reviewed Finding
- > SecurityRequirement
- > effective obligation (FR + SEC)
- > Decision/FR/design revision where required
- > Base Analysis refresh
- > re-analysis

The goal is not merely threat enumeration. The experiment must show whether analysis produces a governed security obligation that changes design/documentation and whether re-analysis can observe the changed state.

O4 - STRIDE-AI second implementation/evaluation method

Use STRIDE-AI as the second in-scope method for thesis implementation/evaluation. It must reuse the same common Base Analysis, AnalysisRecord, Finding and SecurityRequirement contracts.

8. Method-neutrality challenges outside primary implementation scope

After STRIDE and STRIDE-AI, use LINDDUN and optionally one additional method as **neutrality challenges**, not as required implementation/evaluation methods.

Purpose:

- identify assumptions accidentally specific to security-threat taxonomies;
- test whether Base Analysis subjects/relations are sufficiently generic;
- test whether the overlay contract can describe different analytical semantics;
- do not claim full methodology neutrality until these challenges are performed.

9. ThreatForge role

ThreatForge remains a reference implementation/tooling case study. The sequence above first defines DDTA contracts, then checks which contracts ThreatForge supports or must be changed to support.

Do not let current ThreatForge schemas establish the semantic truth of SecurityRequirement, Base Analysis or overlay contracts.

10. Reopen policy

Reopen the MR -> Decision -> FR documentation baseline only if a later phase produces a concrete recurring semantic failure, for example:

- SEC cannot constrain/specialize FR without false duplication or ownership;
- Base Analysis cannot represent facts required by the documented behavior without changing authoring semantics;
- overlay input requires method-specific data to be embedded in MR/Decision/FR;
- the constant Decision layer produces a real semantic contradiction rather than the cost of a rare necessity/default node.

Any reopening must name the counterexample and regress all previously accepted corpora.

11. Next authorized microstep

After Chapter 4 review, start **S1: Minimal SpecializedRequirement semantics**, then **S2: SecurityRequirement semantics**, before Base Analysis or STRIDE construction work.